



АКАДЕМИЯ
КОДЕБАЙ

ПРОФЕССИЯ ПЕНТЕСТЕР

В течение многих лет протокол [Server Message Block \(SMB\)](#) не отличался безопасностью из-за своей сложной реализации и открытого характера. Чего стоят только неаутентифицированные нулевые сессии SMB в Windows 2000 и Windows XP. Тем не менее, протокол SMB также обновлялся и совершенствовался параллельно с выпуском операционных систем Windows.

Эта служба была разработана в 1980-х годах для обеспечения связи между компьютерами в локальных сетях. Она предоставляет приложениям программный интерфейс для доступа к сетевым ресурсам, таким как файлы и принтеры, и позволяет компьютерам обнаруживать друг друга по именам, а не по IP-адресам. Основные функции NetBIOS включают установление соединений, передачу данных и управление сессиями. Хотя NetBIOS использовался в основном в системах Windows, его функции были перенесены и адаптированы в более современные протоколы, такие как SMB (Server Message Block).

Служба NetBIOS работает на трех уровнях: имя (NetBIOS Name Service), сессия (NetBIOS Session Service) и датаграмма (NetBIOS Datagram Service). Имя позволяет компьютерам находить друг друга в сети, сессия управляет соединениями между компьютерами, а датаграмма отвечает за передачу данных. Несмотря на свою популярность в прошлом, использование NetBIOS значительно снизилось с переходом на более безопасные и эффективные протоколы, такие как TCP/IP. Тем не менее, он все еще может встречаться в устаревших сетях и системах, особенно в средах, использующих более старые версии Windows.

Сканирование службы NetBIOS

Служба NetBIOS прослушивает TCP-порт 139, а также несколько UDP-портов. Следует отметить, что SMB (TCP-порт 445) и NetBIOS представляет собой две разных сущности – это и независимый протокол сеансового уровня и служба, которая позволяет компьютерам в локальной сети общаться друг с другом. Хотя современные реализации SMB могут работать [без NetBIOS](#).

Энумерация этих двух служб часто идет рука об руку в тестировании на проникновение. Их можно просканировать с помощью таких инструментов, как Nmap, используя синтаксис, подобный следующему:

```
kali@kali:~$ nmap -v -p 139,445 -oG smb.txt 192.168.0.1-254
```

Есть более специализированные инструменты для получения информации о NetBIOS, например, nbtscan, который используется в следующем примере. Параметр -r используется для указания порта UDP (137), который используется для запроса службы имен NetBIOS:

```
kali@kali:~$ sudo nbtscan -r 192.168.0.1-254
```

```
(kali@kali)-[~]
$ sudo nbtscan -r 192.168.0.1-254
Doing NBT name scan for addresses from 192.168.0.1-254
```

IP address	NetBIOS Name	Server	User	MAC address
192.168.0.130	MBP-ADMIN		<unknown>	b8:8d:12:33:ea:32
192.168.0.141	<unknown>		<unknown>	
192.168.0.174	DESKTOP-JA7CNCQ	<server>	<unknown>	4c:cc:6a:27:6b:fb

Nmap SMB NSE Scripts

Nmap содержит множество полезных сценариев NSE, которые можно использовать для обнаружения и перечисления служб SMB. Эти сценарии можно найти в каталоге /usr/share/nmap/scripts:

```
kali@kali:~$ ls -l /usr/share/nmap/scripts/smb*
```

```
(kali@kali)-[~]
$ ls -l /usr/share/nmap/scripts/smb*
/usr/share/nmap/scripts/smb2-capabilities.nse
/usr/share/nmap/scripts/smb2-security-mode.nse
/usr/share/nmap/scripts/smb2-time.nse
/usr/share/nmap/scripts/smb2-vuln-uptime.nse
/usr/share/nmap/scripts/smb-brute.nse
/usr/share/nmap/scripts/smb-double-pulsar-backdoor.nse
/usr/share/nmap/scripts/smb-enum-domains.nse
/usr/share/nmap/scripts/smb-enum-groups.nse
/usr/share/nmap/scripts/smb-enum-processes.nse
/usr/share/nmap/scripts/smb-enum-services.nse
/usr/share/nmap/scripts/smb-enum-sessions.nse
/usr/share/nmap/scripts/smb-enum-shares.nse
/usr/share/nmap/scripts/smb-enum-users.nse
/usr/share/nmap/scripts/smb-flood.nse
/usr/share/nmap/scripts/smb-ls.nse
/usr/share/nmap/scripts/smb-mbenum.nse
/usr/share/nmap/scripts/smb-os-discovery.nse
/usr/share/nmap/scripts/smb-print-text.nse
/usr/share/nmap/scripts/smb-protocols.nse
/usr/share/nmap/scripts/smb-psexec.nse
/usr/share/nmap/scripts/smb-security-mode.nse
/usr/share/nmap/scripts/smb-server-stats.nse
/usr/share/nmap/scripts/smb-system-info.nse
/usr/share/nmap/scripts/smb-vuln-conficker.nse
/usr/share/nmap/scripts/smb-vuln-cve2009-3103.nse
/usr/share/nmap/scripts/smb-vuln-cve-2017-7494.nse
/usr/share/nmap/scripts/smb-vuln-ms06-025.nse
/usr/share/nmap/scripts/smb-vuln-ms07-029.nse
/usr/share/nmap/scripts/smb-vuln-ms08-067.nse
```

Здесь мы находим несколько интересных сценариев, которые выполняют различные задачи, такие как обнаружение и перечисление ОС через SMB.

Давайте попробуем использовать скрипт smb-os-discovery:

```
kali@kali:~$ nmap -v -p 139, 445 --script=smb-os-discovery 192.168.0.174
```

```
PORT      STATE SERVICE
139/tcp   open  netbios-ssn

Host script results:
| smb-os-discovery:
|   OS: Windows 10 Pro 15063 (Windows 10 Pro 6.3)
|   OS CPE: cpe:/o:microsoft:windows_10::-
|   Computer name: DESKTOP-JA7CNCQ
|   NetBIOS computer name: DESKTOP-JA7CNCQ\x00
|   Workgroup: WORKGROUP\x00
|_  System time: 2022-07-17T22:52:10+03:00

NSE: Script Post-scanning.
Initiating NSE at 15:52
Completed NSE at 15:52, 0.00s elapsed
Read data files from: /usr/bin/../share/nmap
Nmap done: 2 IP addresses (1 host up) scanned in 1.65 seconds
```

Этот сценарий определил операционную систему хоста. Для проверки известных уязвимостей протокола SMB мы можем вызвать один из NSE-скриптов smb-vuln. Мы рассмотрим smb-vuln-ms08-067, который использует опцию --script-args для передачи аргументов сценарию NSE.

```
kali@kali:~$ nmap -v -p 139,445 --script=smb-vuln-ms08-067 --script-args=unsafe=1 192.168.0.174
```

```
└─$ nmap -v -p 139,445 --script=smb-vuln-ms08-067 --script-args=unsafe=1 192.168.0.174
Starting Nmap 7.92 ( https://nmap.org ) at 2022-07-17 15:59 EDT
NSE: Loaded 1 scripts for scanning.
NSE: Script Pre-scanning.
Initiating NSE at 15:59
Completed NSE at 15:59, 0.00s elapsed
Initiating Ping Scan at 15:59
Scanning 192.168.0.174 [2 ports]
Completed Ping Scan at 15:59, 0.00s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 15:59
Completed Parallel DNS resolution of 1 host. at 15:59, 0.01s elapsed
Initiating Connect Scan at 15:59
Scanning 192.168.0.174 [2 ports]
Discovered open port 139/tcp on 192.168.0.174
Discovered open port 445/tcp on 192.168.0.174
Completed Connect Scan at 15:59, 0.00s elapsed (2 total ports)
NSE: Script scanning 192.168.0.174.
Initiating NSE at 15:59
Completed NSE at 15:59, 0.06s elapsed
Nmap scan report for 192.168.0.174
Host is up (0.0038s latency).

PORT      STATE SERVICE
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds

NSE: Script Post-scanning.
Initiating NSE at 15:59
Completed NSE at 15:59, 0.00s elapsed
Read data files from: /usr/bin/../share/nmap
Nmap done: 1 IP address (1 host up) scanned in 0.44 seconds
```

Моя система (Windows 10) не подвержена уязвимости [CVE-2008-4250](#), поэтому Nmap не выдал соответствующего сообщения "VULNERABLE" о том что она уязвима.

P.S. Если вы зададите параметр сценария unsafe=1, то будут запущены сценарии, которые почти (или полностью) приведут к краху уязвимой системы. НЕ указывайте этот параметр при работе с клиентами! Это

конечно не означает, что небезопасные сценарии не приведут к краху системы, просто вероятность этого меньше.

Команды, используемые в уроке:

```
kali@kali:~$ nmap -v -p 139,445 -oG smb.txt 192.168.0.1-254
```

```
kali@kali:~$ sudo nbtscan -r 192.168.0.1-254
```

```
kali@kali:~$ ls -l /usr/share/nmap/scripts/smb*
```

```
kali@kali:~$ nmap -v -p 139, 445 --script=smb-os-discovery 192.168.0.174
```

```
kali@kali:~$ nmap -v -p 139,445 --script=smb-vuln-ms08-067 --script-args=unsafe=1 192.168.0.174
```